AIG-AGT-01 · The Council · AI GOVERNANCE

Agentic AI Governance

Design principles for the agentic governance layer

UC-ID system/use identity — AIR-ID identifies the agentic system, not every authorised purpose. Assign a separate UC-ID to each materially distinct agent use/outcome and scope risk, priority, delegated decision, authority envelope, conditions and monitoring to that UC-ID. Ordinary non-agentic uses still receive UC-IDs; only action-capable configurations invoke agentic controls. No system baseline or agent authority graph grants blanket use approval.

Field	Controlled value
Document title	Agentic AI Governance: Design Principles
Version	1.6 draft
Status	Draft for Council review; pre-adoption; nothing evidenced until operated
Author	AI Governance Lead
Date	12 October 2026
Purpose	The rules the whole agentic layer must satisfy: the record, the triage, the controls and the operating model are all built to these
Proposed placement	Head of the agentic governance layer (Playbook Appendix F), ahead of the Agent Record, Authority Graph and Agentic Triage
Primary source	OWASP GenAI Security Project 2026 agentic guidance; Playbook Appendix F.1 (core principle and invariants)
Classification	OFFICIAL
Change history	1.1 draft, 29 September 2026: QA remediation — applied findings QA-088, QA-120, QA-166, QA-200 (see QA change log). Supersedes the unnumbered working draft of 19 September 2026. Final tidy-up: self-referencing cross-reference removed from the standards row(s) REQ-039. 1.2 draft, 30 September 2026: v3.9.1: standards cross-reference note updated to the 54-entry requirement inventory (AIG-AIMS-05 REQ-054, Civil Contingencies Act 2004, added). 1.3 draft, 1 October 2026: v3.9.3: standards cross-reference note cites the 55-entry requirement inventory (AIG-AIMS-05 REQ-055, NIST AI 600-1 Generative AI Profile, added). 1.4 draft, 2 October 2026: v3.9.5: standards cross-reference note cites the 56-entry requirement inventory (AIG-AIMS-05 REQ-056, SI 2026/425 ICO statutory code of practice on AI and automated decision-making, added). Proposed — for Council confirmation. 1.5 draft, 4 October 2026: v3.9.9: the Agent Record principle notes the proportionate record levels (core for every agent; features add sheets; full ASBOM at T3 and above; Playbook F.3). Proposed — for Council confirmation. 1.6 draft, 12 October 2026: v3.9.10: standards cross-reference note cites the 58-entry requirement inventory (AIG-AIMS-05 REQ-057 DAMA-DMBOK and REQ-058 ISO/IEC 5259, added as voluntary data governance references). Proposed — for Council confirmation.

1. Why this document exists

The agentic layer is being built foundation-first, so that it can evolve as agentic AI progresses rather than being retrofitted. These principles are the foundation. Every artefact that follows, the Agent

Record, the Authority Graph, the Agentic Triage and the runtime controls, must satisfy them. If a later design choice conflicts with a principle here, the principle wins or the principle is deliberately changed; it is not quietly overridden.

The shift they encode is this: agentic governance no longer governs a model, it governs a delegated actor operating in an environment. These principles are written to survive whatever the technology does next.

2. The core principle

The single rule the whole layer is built around:

> No autonomous AI system may possess authority that cannot be attributed, bounded, monitored, interrupted, revoked and, where technically feasible, reversed.

Two rules support it and close the ways authority tends to leak:

> No agent may acquire additional authority merely through its own reasoning, memory, persuasion, delegation, tool discovery, model selection or interaction with another agent.
>
> Every transfer of authority between humans, agents, models, tools, systems or organisations must be explicitly governed and auditable.

3. The five invariants

Whatever else changes, these five must hold for every agent, at every autonomy level, including the lowest. They are the floor, and the safety net for when a classification turns out to be wrong.

Attribution
Every consequential action can be traced to the actor that took it. No action is anonymous.

Authority
Every action rests on authority that was explicitly delegated and recorded. Nothing acts on assumed or self-granted permission.

Observability
What an agent did, and why, can be reconstructed at the action level, without requiring disclosure of private internal reasoning.

Controllability
The agent can be stopped, its credentials revoked and its tools disabled without delay, and this can be demonstrated, not merely claimed.

Accountability
A named human is answerable for each agent's outcomes. Responsibility does not evaporate because a machine acted.

4. The operating stance: capture wide, govern proportionately, fail safe

The safest comprehensive approach is a wide net at the door and proportionate depth behind it. Assessing everything to the maximum is not safer, because heavy governance drives people to route around it, and shadow agents are the largest capture failure of all.

- Capture wide: Everything enters one route and one AIR-ID, and is assumed in scope until proven out. The question is which path, never whether it is governed at all.
- Govern proportionately: Width lives at intake, depth lives in the tiering. A trivial tool gets a light record; only high-agency systems get the heavy treatment.

- Fail safe: When agency, authority or containment is unclear, the system is treated at the higher tier until assessed. Unknown escalates; it is never waved through. Nothing goes live that cannot be demonstrably stopped and its actions reconstructed.

5. Govern capability, not intention

Governance attaches to what an actor can technically do, not to what it is intended or instructed to do. Capability is not intention: an agent may be told not to do something it remains technically able to do, and instruction is not a control. So the authority envelope, the maximum an agent can do without asking anyone, is the governed object, and the classic failure to look for is capability exceeding intended authority.

6. Architecture-neutral controls

Controls are written around the actor and the action, not around today's tools, so they survive architectural change. The test to apply to any proposed control is whether it still makes sense two model generations from now.

- Avoid: "Every LLM call must include X." That is tied to today's architecture and will age badly.
- Prefer: "Every autonomous actor must possess bounded authority, attributable identity, observable execution and a controllable termination path." That holds whatever the actor is built from.

7. Governance follows the action, not only the system

Because the same agent moves between risk states as its action and authority change, governance is dynamic, not a single classification at deployment. Intensity scales with agency, capability, consequence and uncertainty, evaluated where the consequential action occurs. A static, one-time assessment is treated as insufficient for anything that can act.

8. How these principles bind the rest of the build

Each foundation artefact is accountable to specific principles, so the layer holds together rather than drifting.

- The Agent Record (ASBOM): must make attribution, authority and accountability legible for every agent, and record the authority envelope (principles 2, 3, 5). It is proportionate: every agent has the core record, features add their sheets, and the full ASBOM applies at T3 and above (Playbook F.3; Proposed — for Council confirmation).
- The Authority Graph: must make every delegation of authority explicit and auditable, and reversible (principles 2, 3).
- The Agentic Triage: must capture wide, fail safe on ambiguity, and re-evaluate dynamically (principles 4, 7).
- The runtime controls: must deliver observability and controllability in operation, and enforce that authority is bounded and continuously checked (principles 2, 3, 7).

9. Status and source

This is a draft for Council review, pre-adoption. Nothing in the agentic layer is evidenced until it is operated, and adoption of the layer is a decision not yet taken. The core principle and the supporting rules, and the five invariants, are set out in Playbook Appendix F.1; the control expectations they encode align with the OWASP Agent Control Standard (released 1 September 2026) and the OWASP Top 10 for Agentic Applications 2026, verified against genai.owasp.org on 19 September 2026.

Draft for Council review. The foundation the Agent Record, Authority Graph and Agentic Triage are built to satisfy.

Additional mandatory design principles

- Authority never escalates through delegation, memory, tool output, agent-to-agent messages or dynamic discovery.
- Capability is governed as a technical vector; intention alone is not a control.
- Frontier model status is separate from consequence/high-impact classification.
- Runtime controls are represented as operational only when implemented and evidenced.
- Every consequential action must be attributable and reconstructable without requiring private chain-of-thought.
- No unbounded delegation, recursion, agent creation or swarm behaviour is permitted unless explicitly assessed and authorised.
- Every boundary crossing must identify the authority and data crossing it.
- Every persistent memory store must have provenance, retention, deletion and poisoning controls.

Operational simplification rules

Agentic governance is an extension of the existing AI lifecycle, not a separate governance programme.

- One front door and one AIR-ID remain mandatory.
- Agentic controls trigger only when the AI can exercise consequential delegated authority or another defined agentic trigger is present.
- The Agent Record/ASBOM is the single authoritative agentic record.
- The Authority Graph is a derived view from ASBOM authority/delegation data.
- Agentic capability, autonomy, memory, interfaces and tool authority should be captured once and reused across assurance.
- Do not require a separate form where an existing record can hold the evidence.
- Runtime enforcement must be evidenced by the technical control owner; documentation alone is not implementation evidence.

NOT APPROVED — PROPOSED INTEGRATION ANNEX

Integration annex — Agentic-layer record boundaries and lifecycle links

DRAFT FOR COUNCIL REVIEW • 25 September 2026 • Not approved for operational use

Principles remain design requirements

These principles remain the native design basis for the agentic governance layer, not evidence of implementation. Retain the distinctions among system AIR-ID, agent identity, model, delegated authority and action; do not infer operational control from a design statement or documentation alone.

Authoritative agent and action records

After AIR-ID registration in AIG-INV-04, link each in-scope agent to the exact proposed stable AG-ID and version in AIG-AGT-04, which owns the agent composition/permissions/delegations. AIG-AGT-05 is a derived view of AIG-AGT-04 authority/delegation data and does not grant or independently establish permission. AIG-AGT-06 is the action-specific decision record; use it for relevant action-level traceability, not as an AIG-DEC-04 gate event. Runtime implementation/effectiveness requires evidence from the technical control owner, indexed in AIG-INV-04 by Evidence ID, source/version, observation date and location.

Lifecycle and governance events

Use AIG-OPS-02 for operational monitoring, reassessment and material changes to agent, model, supplier, tools, memory, interfaces or authority envelope. Update AIG-INV-04 current state/relationships as needed. Cite AIG-DEC-04 only for an actual dated Gate Event or Condition (ID and date); no plan or derived graph is evidence of an event. The authorised governance decision remains in AIG-DEC-03 or authoritative forum minutes, with AIG-DEC-04 only pointing to the dated decision/event.

Rights and draft status

Where agents make or materially influence decisions about people, link the relevant AIG-OPS-04 route and appropriate native assessments; a reference does not prove a right is engaged or a safeguard works. This proposed annex grants no agent permission, evidences no control operation or result, and asserts no legal applicability, approval, or public publication.

Standards and legal applicability — proposed QA cross-reference

Keep service capabilities distinct from agent authority

The proposed AIG-INV-05 catalogue records business/service capabilities and descriptive system relationships; it is not the five-dimension agentic profile in AIG-AGT-02/AIG-AGT-03 and does not encode an agent’s capability vector, permission or delegation. Keep system AIR-ID in AIG-INV-04, stable AG-ID and actual agent composition/authority in AIG-AGT-04, derived delegation paths in AIG-AGT-05, dated gate events/conditions in AIG-DEC-04, and action-level execution evidence in AIG-AGT-06. A map link cannot establish that an agent is authorised or safe.

PROPOSED QA INDEX — NOT APPROVED LEGAL ADVICE OR EVIDENCE OF COMPLIANCE. The listed instruments may be relevant to this artefact, but applicability depends on the case, service and Council delegation. Legislation, official guidance, Council policy and voluntary standards are different authority classes. The full 58-entry requirement inventory, authoritative URLs, validation owners and current versions are in AIG-AIMS-05; source checks are in AIG-AIMS-13. Do not treat a template, plan or cross-reference as completed assessment, adopted policy, ISO conformity or legal sign-off.

Requirement / instrument	Why check it here	Source
REQ-039 — NCSC Guidelines for Secure AI System Development	Screen the government security guidance requirement against this artefact's actual use and record evidence/version.	https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/introduction
REQ-040 — ISO/IEC 42001:2023 Artificial intelligence management system	Proposed management-system design mapping; licensed clause review and adoption needed.	https://www.iso.org/standard/42001
REQ-041 — ISO/IEC 23894:2023 AI — Guidance on risk management	Voluntary risk-management guidance; proposed alignment, not statutory conformity.	https://www.iso.org/standard/77304.html
NIST-AI-100-1 — NIST AI Risk Management Framework 1.0 (NIST AI 100-1, January 2023)	Voluntary alignment reference; not certification or statutory conformity	https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10
OWASP-ACS-2026 — OWASP Agent Control Standard	Technical design guidance; verify operational tests	https://genai.owasp.org/resource/agent-control-

(OWASP GenAI Security Project, released 1 September 2026)	standard-acs/